

PROYECTO:

**EVALUACION DE CUMPLIMIENTO NORMATIVO EN
IMPLEMENTACIÓN DE RED SEGMENTADA PARA PEQUEÑA
OFICINA, TECHNOLOGY C.A.**

Fecha de Actualización: 1 de Agosto de 2026

Elaborado por: Eleonor Arias H.

Versión: 1.0

INDICE

1. Objetivo del Proyecto

2. Alcance y Topología de Red

3. Marco Teórico y Conceptual

3.1. ¿Qué es una VLAN?

3.2. ¿Por qué integrar VLANs?

3.3. Principio de "Privacidad por Diseño"

4. Arquitectura de Red Implementada

5. Implicaciones Legales y de Cumplimiento (El Valor para la Empresa)

5.1. GDPR (Reglamento General de Protección de Datos)

5.2. Directiva NIS2 (Ciberseguridad)

5.3. ISO 27001:2022

5.4. Reducción de la Responsabilidad Civil y Penal

6. Conclusiones y Recomendaciones

1. OBJETIVO DEL PROYECTO

El presente proyecto tiene como objetivo diseñar e implementar una infraestructura de red local (LAN/WLAN) para una oficina corporativa de tamaño pequeño/mediano. El propósito principal fue demostrar la capacidad de configurar equipos de red (Router, Switch y Access Points) aplicando buenas prácticas de ciberseguridad mediante la segmentación de red (VLANs) y la implementación de un firewall perimetral (ACLs). Existe la necesidad crítica de proteger la información corporativa frente a amenazas internas y externas, por ello, se ha diseñado una red basada en el principio de "Confidencialidad y Mínimo Privilegio".

Se utiliza la segmentación lógica (VLANs) y un firewall perimetral (ACLs), garantizando que los datos de los departamentos de Administración, Ventas y Recursos Humanos (RRHH) estén estrictamente aislados entre sí, y que el acceso a los servidores corporativos esté restringido únicamente a los servicios autorizados (puertos web).

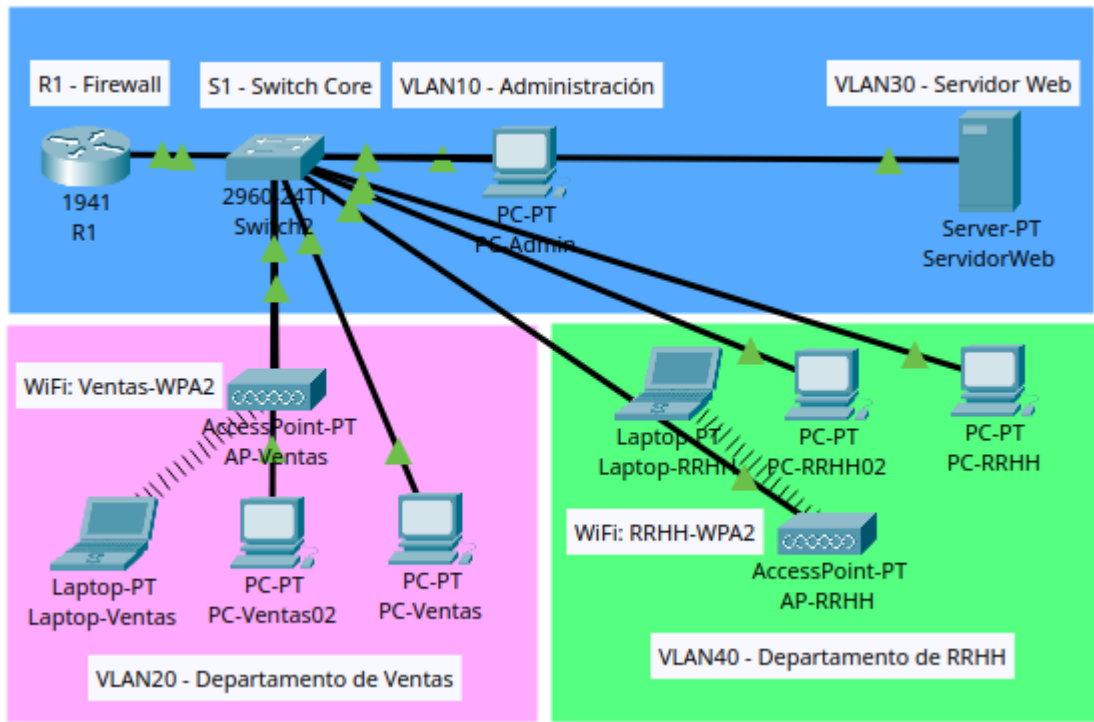
Este diseño mitiga el riesgo de filtración de datos, limita el movimiento lateral de posibles atacantes y demuestra el compromiso de la organización con el cumplimiento de normativas como el GDPR (Reglamento General de Protección de Datos), la Directiva NIS2 y la ISO 27001.

2. ALCANCE Y TOPOLOGÍA DE RED

Se desplegaron los siguientes componentes lógicos y físicos:

COMPONENTE	MODELO	FUNCIÓN
ROUTER	CISCO 1941	Puerta de enlace (Gateway), enrutador entre VLANs y Firewall (ACLs).
SWITCH	CISCO 2960-24TT	Dispositivo de capa 2 encargado de la segmentación física y lógica (VLANs).
ACCESS POINTS	CISCO WAP4410N	Proporcionar conectividad inalámbrica a los equipos móviles de los departamentos.
SERVIDOR WEB	SERVER-PT	Alojar los servicios internos de la empresa (HTTP).
ESTACIONES DE TRABAJO	PC-PT / LAPTOP-PT	PCs cableadas y Laptops distribuidas por departamentos.

Imagen 1: Topología de red completa en Cisco Packet Tracer.



3. MARCO TEÓRICO Y CONCEPTUAL

3.1. ¿Qué es una VLAN (Virtual Local Area Network)?

Una VLAN es una red local virtual que segmenta lógicamente una red física. Permite agrupar dispositivos independientemente de su ubicación física, mejorando la seguridad, reduciendo el tráfico de broadcast y simplificando la administración. En el modelo OSI, las VLANs operan en la capa 2 (Enlace de Datos), creando dominios de broadcast independientes dentro de un mismo switch o conjunto de switches.

3.2. ¿Por qué integrar VLANs?

La implementación de VLANs responde a una necesidad de arquitectura de seguridad Zero Trust (Confianza Cero):

1. Aislamiento de Tráfico (Broadcast): Sin VLANs, todas las PCs estarían en un único dominio de broadcast. Esto genera tráfico innecesario que consume ancho de banda y permite que un dispositivo "vea" a todos los demás. Con VLANs, el tráfico de broadcast queda encapsulado dentro de su propio departamento.
2. Contención de Amenazas: Si un equipo de Ventas se infecta con malware, el tráfico malicioso queda confinado a la VLAN 20. Esto provoca que el atacante no pueda moverse lateralmente (por ejemplo, de Ventas a RRHH o al Servidor) a menos que el firewall se lo permita expresamente.
3. Principio de Mínimo Privilegio: A nivel de red, esto significa que un usuario solo tiene acceso a los recursos necesarios para cumplir su función. Un trabajador del departamento de Ventas no necesita ver los archivos de nómina de RRHH, y RRHH no necesita acceder a los sistemas de gestión de clientes de Ventas sin autorización expresa.

3.3. Principio de "Privacidad por Diseño" (Privacy by Design)

La norma exige que la seguridad no sea un "añadido", sino que esté integrada en la arquitectura desde el inicio.

Demostración Práctica: Al configurar VLANs y ACLs, la seguridad está integrada en el "ADN" de la red. No es un parche, es una funcionalidad base del sistema.

Cumplimiento de la ISO 27001: La implementación responde a múltiples controles de la norma internacional de gestión de seguridad de la información:

Anexo A.8.20 (Seguridad de redes): Se protegen los datos en tránsito y se defiende la red de amenazas internas y externas mediante firewalls y listas de control de acceso.

Anexo A.8.22 (Segregación de redes): Se separan los servicios, usuarios y sistemas según el riesgo, aislando las redes de producción, servidores, estaciones de trabajo y WiFi.

Anexo A.9 (Control de acceso): Se gestiona el acceso lógico a la red y los servicios de red, restringiendo el acceso únicamente a los usuarios y departamentos autorizados.

4. ARQUITECTURA DE RED IMPLEMENTADA

4.1. Tabla de Segmentación (VLANs)

VLAN	NOMBRE	RED IP	GATEWAY	USO
10	Administración	192.168.10.0/24	192.168.10.1	Equipo crítico y dirección general
20	Ventas	192.168.20.0/24	192.168.20.1	Equipos cableados e inalámbricos del equipo comercial
30	Servidores	192.168.30.0/24	192.168.30.1	Servidor Web corporativo
40	Recursos Humanos	192.168.40.0/24	192.168.40.1	Equipos cableados e inalámbricos de RRHH

Imagen 2: Verificación de puertos y VLANs en el Switch General.

```
Switch>enable
Switch#show interfaces status
Port      Name      Status      Vlan      Duplex  Speed  Type
Fa0/1     Fa0/1     connected   10        a-full  a-100  10/100BaseTX
Fa0/2     Fa0/2     connected   20        a-full  a-100  10/100BaseTX
Fa0/3     Fa0/3     connected   20        a-full  a-100  10/100BaseTX
Fa0/4     Fa0/4     connected   40        a-full  a-100  10/100BaseTX
Fa0/5     Fa0/5     connected   40        a-full  a-100  10/100BaseTX
Fa0/6     Fa0/6     connected   30        a-full  a-100  10/100BaseTX
Fa0/7     Fa0/7     connected   20        a-full  a-100  10/100BaseTX
Fa0/8     Fa0/8     connected   40        a-full  a-100  10/100BaseTX
Fa0/9     Fa0/9     notconnect  1         auto    auto   10/100BaseTX
Fa0/10    Fa0/10    notconnect  1         auto    auto   10/100BaseTX
Fa0/11    Fa0/11    notconnect  1         auto    auto   10/100BaseTX
Fa0/12    Fa0/12    notconnect  1         auto    auto   10/100BaseTX
Fa0/13    Fa0/13    notconnect  1         auto    auto   10/100BaseTX
Fa0/14    Fa0/14    notconnect  1         auto    auto   10/100BaseTX
Fa0/15    Fa0/15    notconnect  1         auto    auto   10/100BaseTX
Fa0/16    Fa0/16    notconnect  1         auto    auto   10/100BaseTX
Fa0/17    Fa0/17    notconnect  1         auto    auto   10/100BaseTX
Fa0/18    Fa0/18    notconnect  1         auto    auto   10/100BaseTX
Fa0/19    Fa0/19    notconnect  1         auto    auto   10/100BaseTX
Fa0/20    Fa0/20    notconnect  1         auto    auto   10/100BaseTX
Fa0/21    Fa0/21    notconnect  1         auto    auto   10/100BaseTX
--More-- |
```

4.2 Configuración del Router (Firewall)

Imagen 3: Configuración de subinterfaces en el Router.

```
R1>enable
R1#show ip interface brief
Interface      IP-Address      OK? Method Status      Protocol
GigabitEthernet0/0    unassigned      YES unset   up          up
GigabitEthernet0/0.10 192.168.10.1    YES manual  up          up
GigabitEthernet0/0.20 192.168.20.1    YES manual  up          up
GigabitEthernet0/0.30 192.168.30.1    YES manual  up          up
GigabitEthernet0/0.40 192.168.40.1    YES manual  up          up
GigabitEthernet0/1    unassigned      YES unset   down        down
Vlan1           unassigned      YES unset   up          down
R1#
```

Imagen 4: Lista de acceso (ACL) aplicada en el Router.

```
R1#show access-lists
Extended IP access list 110
 10 deny ip 192.168.20.0 0.0.0.255 192.168.10.0 0.0.0.255
 20 deny ip 192.168.40.0 0.0.0.255 192.168.20.0 0.0.0.255
 30 deny ip host 192.168.20.21 host 192.168.20.11
 40 deny ip host 192.168.20.21 host 192.168.20.12
 50 deny ip host 192.168.40.21 host 192.168.40.11
 60 deny ip host 192.168.40.21 host 192.168.40.12
 70 permit tcp any host 192.168.30.10 eq www
 80 deny ip any host 192.168.30.10
 90 permit ip any any
```

4.3. Configuración de Access Points (Wi-Fi)

AP	SSID	VLAN	Seguridad	Contraseña
AP VENTAS	VENTAS-WIFI	20	WPA2-PSK	Ventas2026
AP RRHH	RRHH-WIFI	40	WPA2-PSK	RRHH2026

Imagen 5: Configuración Wi-Fi del AP Ventas.

Port Status

On

SSID

Ventas-Wifi

2.4 GHz Channel

6

Coverage Range (meters)

140,00

Authentication

Disabled

WEP

WPA-PSK

WPA2-PSK

WEP Key

PSK Pass Phrase

Ventas123

User ID

Password

Encryption Type

AES

4.4. Control de Accesos (Firewall)

El punto de conexión entre estas redes es un Firewall (integrado en el router corporativo) que aplica políticas de acceso restrictivas.

¿Por qué configurar un Firewall basado en ACLs?

El router, al ser el punto de entrada entre las VLANs, funciona como un Firewall de Capa 3 y 4.

1. **Control de Acceso:** Las ACLs (Access Control Lists) actúan como un filtro. Permiten o deniegan el tráfico basándose en la dirección IP origen, IP destino, protocolo (TCP/UDP) y puerto.
2. **Protección del Servidor Web:** Implementamos una regla crítica: Todos pueden ver el servidor (puerto 80/HTTP), pero nadie puede administrarlo (puerto 22/SSH o ping). Esto reduce la superficie de ataque del servidor, cumpliendo con normativas de ciberseguridad como el OWASP Top 10 en cuanto a configuración segura.

Políticas de Seguridad Aplicadas:

ORIGEN	DESTINO	ACCIÓN	JUSTIFICACIÓN
Administración	VENTAS, RRHH	Denegado	Aísla el departamento crítico del resto de la red.
Ventas	Administración, RRHH	Denegado	Evita que el personal comercial acceda a información financiera y de RRHH.
RRHH	Administración, Ventas	Denegado	Protege los datos de nómina del acceso del equipo comercial y viceversa.
Cualquier Red	Servidor Web	Permitido (Solo HTTP)	Permite la operativa de la página web corporativa, pero protege el servidor de ataques de denegación de servicio (DoS) o intentos de acceso remoto (SSH), ya que estos protocolos están bloqueados.

5. IMPLICACIONES LEGALES Y DE CUMPLIMIENTO (EL VALOR PARA LA EMPRESA)

La configuración técnica descrita tiene un impacto directo en la postura legal de la empresa. A continuación, se detalla cómo la segmentación de red y el control de accesos implementados cumplen con las principales normativas internacionales, así como su adaptación al marco normativo del país donde se domicilie la organización.

5.1. GDPR (Reglamento General de Protección de Datos - UE 2016/679)

El GDPR es el estándar de referencia en materia de protección de datos a nivel mundial. Su **Artículo 32 (Seguridad del Tratamiento)** es el más relevante para este proyecto:

"El responsable y el encargado del tratamiento aplicarán medidas técnicas y organizativas apropiadas para garantizar un nivel de seguridad adecuado al riesgo, que en su caso incluirá, entre otros: la seudonimización y el cifrado de datos personales; la capacidad de garantizar la confidencialidad, integridad, disponibilidad y resiliencia permanentes de los sistemas y servicios de tratamiento; la capacidad de restaurar la disponibilidad y el acceso a los datos personales de forma rápida en caso de incidente físico o técnico; y un proceso de verificación, evaluación y valoración regulares de la eficacia de las medidas técnicas y organizativas para garantizar la seguridad del tratamiento."

Demostración Práctica de Cumplimiento:

Requisito del Art. 32 GDPR	Implementación en este Proyecto	Evidencia Técnica
Confidencialidad	VLANs y ACLs garantizan que solo el personal autorizado acceda a los datos de su departamento.	<pre>R1#show access-lists Extended IP access list 110 10 deny ip 192.168.20.0 0.0.0.255 192.168.10.0 0.0.0.255 20 deny ip 192.168.40.0 0.0.0.255 192.168.20.0 0.0.0.255 30 deny ip host 192.168.20.21 host 192.168.20.11 40 deny ip host 192.168.20.21 host 192.168.20.12 50 deny ip host 192.168.40.21 host 192.168.40.11 60 deny ip host 192.168.40.21 host 192.168.40.12 70 permit tcp any host 192.168.30.10 eq www 80 deny ip any host 192.168.30.10 90 permit ip any any</pre>
Integridad	El aislamiento evita la modificación no autorizada de datos por parte de otros departamentos.	Segmentación de red por VLANs.
Medidas Técnicas	Firewall perimetral que controla el tráfico entrante y saliente.	ip access-group 100 in aplicado a la interfaz del router.
Evaluación de Riesgos	La segmentación es una respuesta directa al riesgo de filtración de datos interna.	Diseño arquitectónico basado en "Mínimo Privilegio".

5.2. Directiva NIS2 (UE 2022/2555) - Ciberseguridad

La Directiva NIS2 establece medidas para garantizar un elevado nivel común de ciberseguridad en la Unión Europea. Su **Artículo 21.2** exige que las entidades adopten medidas técnicas y metodológicas para gestionar los riesgos de ciberseguridad.

Requisitos NIS2 Aplicables y su Implementación Técnica:

Requisito NIS2	Implementación en este Proyecto
Políticas de control de acceso	ACLs que deniegan el tráfico entre departamentos no autorizados.
Seguridad de las redes	Segmentación mediante VLANs, aislando el tráfico de broadcast y limitando el movimiento lateral.
Gestión de incidentes	Al limitar el alcance de un posible ataque a una VLAN, se facilita la contención y respuesta.
Seguridad de la cadena de suministro	El aislamiento de servidores (VLAN 30) protege los activos críticos de accesos desde redes menos confiables.

Reglamento de Ejecución (UE) 2024/2690 de la Comisión: Este reglamento establece las medidas técnicas y metodológicas para la gestión de riesgos de ciberseguridad a que se refiere el artículo 21.2 de la NIS2. La segmentación de red y el control de accesos son medidas expresamente recomendadas en las guías técnicas de la **ENISA (Agencia de la Unión Europea para la Ciberseguridad)** para el cumplimiento de la NIS2.

5.3. ISO/IEC 27001:2022 (Sistemas de Gestión de Seguridad de la Información)

La norma ISO 27001 es el estándar internacional para Sistemas de Gestión de Seguridad de la Información (SGSI). Los controles implementados en este proyecto responden directamente a varios anexos:

Control ISO 27001:2022	Implementación en este Proyecto
Anexo A.8.20 (Seguridad de redes)	Se protegen los datos en tránsito y se defiende la red de amenazas internas y externas mediante firewalls y listas de control de acceso.
Anexo A.8.22 (Segregación de redes)	Se separan los servicios, usuarios y sistemas según el riesgo, aislando las redes de producción, servidores, estaciones de trabajo y WiFi.
Anexo A.9.1.2 (Control de acceso a la red)	Se gestiona el acceso lógico a la red y los servicios de red, restringiendo el acceso únicamente a los usuarios y departamentos autorizados.

5.4. Reducción de la Responsabilidad Civil y Penal

La configuración técnica descrita tiene un impacto directo en la reducción de la responsabilidad de la empresa:

1. Mitigación del Daño en Caso de Ciberataque

- A) **Escenario con Red Plana (Sin Segmentación):** Un ransomware infecta un equipo de Ventas. El malware se propaga libremente a toda la red (Administración, RRHH, Servidores), encriptando el 100% de los datos corporativos. La empresa no puede operar por días/semanas. La indemnización a los empleados (por filtración de datos personales) y las penalizaciones de la Agencia de Protección de Datos son máximas.
- B) **Escenario con Red Segmentada (Este Proyecto):** Un ransomware infecta un equipo de Ventas (VLAN 20). El malware queda **confinado a la VLAN de Ventas**. Los servidores (VLAN 30) y los departamentos de Administración (VLAN 10) y RRHH (VLAN 40) no se ven afectados. La empresa puede seguir operando. El daño es limitado a un solo departamento. La indemnización y las penalizaciones se reducen drásticamente. La empresa **puede demostrar que actuó con la debida diligencia** al implementar medidas de seguridad técnicas adecuadas.

2. Implicación Legal del Principio de "Debida Diligencia"

- A) **Art. 32 GDPR:** Exige que el responsable del tratamiento implemente medidas técnicas y organizativas apropiadas al riesgo.
- B) **Prueba de Cumplimiento:** Este proyecto demuestra que la empresa ha implementado medidas de segregación de red y control de accesos. **La empresa tiene evidencia técnica (capturas de configuración, logs) para demostrar a la Agencia de Protección de Datos que cumplió con su obligación de diligencia.**
- C) **Impacto en Multas:** Si una Agencia de Protección de Datos comprueba que la empresa implementó medidas de seguridad como la segmentación de red y un firewall, la multa se reduce significativamente (o incluso se puede evitar) porque la empresa puede demostrar que actuó de manera proactiva para proteger los datos.

3. ISO 27001 y la "Evidencia de Cumplimiento"

La ISO 27001 exige que la organización mantenga **evidencia documentada** de que los controles se han implementado correctamente.

- Los comandos de configuración (show running-config, show access-lists, show vlan brief) y las pruebas de ping realizadas en este proyecto constituyen dicha evidencia.

6. CONCLUSIONES Y RECOMENDACIONES

6.1. Conclusiones

La implementación de esta arquitectura de red demuestra que la organización está alineada con las mejores prácticas internacionales de ciberseguridad y cumple con los estándares legales exigibles (GDPR, NIS2, ISO 27001).

Principales logros:

1. Segmentación Efectiva: Los departamentos de Administración, Ventas y RRHH están completamente aislados entre sí.
2. Firewall Perimetral: El router aplica políticas de control de acceso que limitan el tráfico entrante y saliente a lo estrictamente necesario.
3. Protección del Servidor: El servidor web solo es accesible a través del puerto 80 (HTTP), protegiéndolo de ataques.
4. Evidencia de Cumplimiento: Se ha generado documentación técnica (comandos, capturas de pantalla, pruebas de ping) que demuestra que las medidas de seguridad se han implementado correctamente.

6.2. Recomendaciones a la Dirección

1. Política de Contraseñas: Se recomienda complementar esta seguridad de red con una política de autenticación robusta (WPA2-Enterprise) para las redes WiFi, cambiando las contraseñas periódicamente.
2. Plan de Respuesta a Incidentes: La tecnología debe ir acompañada de un procedimiento legal/operativo que defina cómo actuar ante una violación de seguridad (quiénes, cómo y en qué plazo se notifica a los afectados y a la Agencia de Protección de Datos).
3. Auditoría Periódica: Revisar las reglas del firewall (ACLs) de forma trimestral para asegurar que ningún usuario o departamento nuevo adquiera permisos innecesarios.
4. Cifrado de Datos: Considerar la implementación de cifrado en los servidores y dispositivos móviles para una capa adicional de seguridad.
5. Evaluación de Impacto (EIPD): Realizar una Evaluación de Impacto de Protección de Datos (EIPD) para identificar y mitigar los riesgos específicos de la organización.